Semgrep CE□ Android □□ □□

□□ □ 2□□ □□□ □□□□, false positive triage□ AI□ □□□□ □□ □□□ □□□□□.

□□ □□□ □□

- □□ □□: `Semgrep Community Edition CLI` + □□ □□□ □□ □
- □□ □□: Registry, □□ rule pack, AppSec Platform/Pro, `p/java`, `p/kotlin`, `p/default`
- □□ □□□□□ □ `2□` □ □□□□.
- □ □□□ □□ □□□ □□□□□.

```
□□ □□
→ □□□ sample □□
→ Semgrep rule □□
→ □□ □□ / output
→ false positive sample
→ AI triage □□
```

□□ □□ □□

```
android-project/
├── app/src/main/kotlin/com/example/PendingIntentLab.kt
├── app/src/main/java/com/example/LegacyCrypto.java
└── rules/android-local.yml
```

```
semgrep scan --metrics=off \
  --config rules/android-local.yml \
  app/src/main
```

- □□□ □ □□□□ □ `2□` □ □□□.
- □□□ "□□ □□□"□ □□□, □□□ □□□ □□□□ triage □□□ □□□ □ □□□□.

Sample 1: □□□ □□□□

`android-pendingintent-flag-mutable`

- `PendingIntent`□ □□□ `Intent` □□□□ □□□, □ □ □□□□ □□□ □□□ □ □□ □□□ □□□ □□□□□.
- □□ □□□ □□□ UI□ □□□, □□ □□□ □□ `PendingIntent`□ □□ □ □□□□□ □□□ □ □□□□.
- □□□ review □□□□ "□ Intent□ □□□ □□□"□ □□□, "□□ □□□ □□ □□ □□ □□□ □ □□□"□□ □□ □□□.

```
App A creates PendingIntent
→ System UI or App B stores token
→ Later send() / notification action
→ Action runs with App A identity
```

Sample 1: □□ □□□ □□□□

□□	□ □□□□
`FLAG_MUTABLE` □ □□□□□ □□	□□ □□ `fillInIntent()` □ □□□□ □□□ □□ □ □□□□.
`FLAG_MUTABLE` + empty / implicit `Intent`	action, data, component, extras□ □□□ □□□ □□□□.
`requestCode = 0` □□ + `FLAG_UPDATE_CURRENT`	□□ □□□ □□□□□ extras□ □□ □ □□□□.
`content://` + URI grant □□	□□□ □□ URI read/write □□ □□□□ □□□ □ □□□□.
□□ □□□□ `FLAG_ONE_SHOT` □□	□□, □□, □□ □□ 1□□ □□□ □□□□ □ □□□□.
notification action□ □□ □□ □□ □□	□□□□·□□ □□□ □□□ □ □□ □□□ □□□□.

- □□ `FLAG_MUTABLE` + implicit `Intent` □□□ □□□□ □□□□.
- Android 14 / target SDK 34+□□□ □ □□□ □□□□□ □□□ □□□□ □□□□□□□.

Sample 1: □□ □□ □□□ □□

```
PendingIntent.getActivity(context, 0, Intent(), PendingIntent.FLAG_MUTABLE)
PendingIntent.getBroadcast(context, 0, Intent("SOME_ACTION"), PendingIntent.FLAG_MUTABLE)
PendingIntent.getService(context, 0, intent, PendingIntent.FLAG_MUTABLE)
PendingIntent.getActivity(context, 0, intent, PendingIntent.FLAG_UPDATE_CURRENT)
PendingIntent.getBroadcast(context, 0, intent, PendingIntent.FLAG_CANCEL_CURRENT)
```

- □□ □□ □ □□□ □□:
  - `setClass`, `setComponent`, `setPackage` □ □□
  - `FLAG_GRANT_READ_URI_PERMISSION` / `WRITE` □ □□
  - □□ `Receiver` / `Service` □ extras□ □□□ □□□
  - □□ □□□□ `FLAG_ONE_SHOT` □ □□ □□□ □□

Sample 1: □□□ sample □□

```
package com.example

class PendingIntentLab {
    fun buildDangerousDelete(context: Context, sensitiveFileUri: Uri): PendingIntent {
        val deleteIntent = Intent("com.example.ACTION_DELETE_FILE").apply {
            data = sensitiveFileUri
            addFlags(Intent.FLAG_GRANT_READ_URI_PERMISSION)
            putExtra("fileId", "report-4412")
        }

        return PendingIntent.getBroadcast(
            context,
            0,
            deleteIntent,
            PendingIntent.FLAG_MUTABLE or PendingIntent.FLAG_UPDATE_CURRENT
        )
    }
}
```

- `FLAG_MUTABLE` : □□ □□ □□□□ □□□ extras□ □□□ □ □□□□.
- `Intent("ACTION")` : explicit component□ □□□ implicit `Intent` □□□.
- `requestCode = 0` : □□ □□□ □□□□ □□ □□□□□□.
- `FLAG_UPDATE_CURRENT` : □□ □□ □□□□ □ extras□ □□□ □ □□□□.

Sample 1: □□□ □□□ □□□

```
val intent = Intent(context, DeleteConfirmActivity::class.java).apply {
    action = "com.example.ACTION_DELETE_FILE"
    setPackage(context.packageName)
    putExtra("fileId", fileId)
}

val pi = PendingIntent.getActivity(
    context,
    notificationId,
    intent,
    PendingIntent.FLAG_IMMUTABLE or
        PendingIntent.FLAG_UPDATE_CURRENT or
        PendingIntent.FLAG_ONE_SHOT
)
```

- □□ □□□:
  - explicit component
  - `FLAG_IMMUTABLE`
  - unique `requestCode`
  - □□ extras
  - □□ □□/□□□ □□ □□□□ receiver□□ □□ □□

Sample 1: Semgrep rule

```yaml
rules:
  - id: android-pendingintent-flag-mutable
    languages: [java, kotlin]
    severity: ERROR
    message: >
      Mutable PendingIntent□□□.
      □□□□ FLAG_IMMUTABLE□ □□□□ □□, mutable□ □ □□□□
      explicit component/package, unique requestCode, □□ extras□ □□ □□□□□□.
    patterns:
      - pattern: PendingIntent.get$METHOD($CTX, $REQ, $INTENT, $FLAGS)
      - metavariable-regex:
          metavariable: $FLAGS
          regex: ((?i).*FLAG_MUTABLE.*)
```

- □ □□□ □□□□□ □□ `FLAG_MUTABLE` □□□□ 1□ □□□□□.
- □□ □□□□ 2□ triage□□ □□□.
- □, "mutable□ □□ □□□□", "Intent□ explicit□□", "□□ red flag□ □□□"□ □□□□ AI□ □□□ □□□□□.

Sample 1: Semgrep□ □□□ □□□□

```
□□ □□
1. PendingIntent.getActivity/getBroadcast/getService □□□ □□□.
2. flags □□ FLAG_MUTABLE□ □□ □□□ □□.
3. finding□ □ □, 2□□ explicit □□ / requestCode / URI grant / □□ action□ review□□.
```

```
val deleteIntent = Intent("com.example.ACTION_DELETE_FILE")
...
return PendingIntent.getBroadcast(
    context, 0, deleteIntent,
    PendingIntent.FLAG_MUTABLE or PendingIntent.FLAG_UPDATE_CURRENT
) // □□ □□
```

- □ □□ "mutable □□□ □□□□"□ □□ □□ review rule□□□.
- □ □□ □□□□ implicit □□, `requestCode = 0`, `FLAG_GRANT_*`, `FLAG_ONE_SHOT` □□□□ □□ □□□.

Sample 1: Semgrep output

```
$ semgrep scan --metrics=off \
    --config rules/android-local.yml \
    app/src/main/kotlin/com/example/PendingIntentLab.kt


┌─────────────────┐
│ 1 Code Finding  │
└─────────────────┘

    app/src/main/kotlin/com/example/PendingIntentLab.kt
   ❯❯❯ android-pendingintent-flag-mutable
          Mutable PendingIntent□□□.
          □□□□ FLAG_IMMUTABLE□ □□□□ □□, mutable□ □ □□□□
          explicit component/package, unique requestCode, □□ extras□ □□ □□□□□□□.

         12┆ return PendingIntent.getBroadcast(
```

- □□□ □□ □□ □□:
  - □ mutable□ □□ □□□□
  - `Intent` □ explicit□□
  - `requestCode`, `URI grant`, `□□ action` □ □□ □□ □□□

Sample 1: □□□□ mutable □□ □□

```
object ReplyActionFactory {
    fun buildReply(context: Context, threadId: Int): PendingIntent {
        val replyIntent = Intent(context, ReplyReceiver::class.java).apply {
            action = "com.example.ACTION_INLINE_REPLY"
            setPackage(context.packageName)
        }

        return PendingIntent.getBroadcast(
            context,
            threadId,
            replyIntent,
            PendingIntent.FLAG_MUTABLE or PendingIntent.FLAG_UPDATE_CURRENT
        )
    }
}
```

- notification inline reply□□ □□□□ `RemoteInput` □□□ □□□ □□ □□□□ mutable□ □□□ □□□ □ □□□□.
- □ □□□□ component/package□ □□□□, mutable □□□□ □□□□□□ □□ □□□□ □□□.

Sample 1: AI triage □□□

```
1. □ use case□ inline reply / bubble / alarm □□□ mutable□ □□ □□□□ □□□□.
2. Intent□ explicit component □□ package□ □□□ □□□ □□□□.
3. requestCode□ □□□□, FLAG_UPDATE_CURRENT□ □□ extra□ □□□□ □□□ □□.
4. URI grant, □□ action, □□ receiver/service□ extra □□ □□□ □□ □□.
5. □□□ □□ □□ mutable□□ true positive□, □□□ □□□ use case□ allowlist □□□ □□□□.
```

Sample 2: □□□ □□□□

`java-android-weak-hash-md1-sha1`

- □□ □□: `SHA-1`, `MD1`, `HmacSHA1`, `SHA1withRSA` □□ □□ □□□□ □□
- □□ □□: □□□ □□, □□ □□, □□ □□, □□□□ □□□ □□□ □□
- □ □□□□:
  - □□ □□ □□□□ □□ □□□ □□ □□
  - "□□□□□ □□□" □□ □□ □□□ □□
  - □□ □□□ □□□ □□□ □□

```
□□ □□
- □ □□□ □□ □□□□□ □□□□?
- □□ □□/□□□□□, □□□□□?
- SHA-256 □□□□ □□ □ □□□?
```

Sample 2: □□□ sample □□

```java
package com.example;

import java.security.MessageDigest;
import java.security.Signature;
import java.util.Arrays;

class LegacyCrypto {
    boolean verifyManifest(byte[] manifest, byte[] expectedDigest) throws Exception {
        byte[] actual = MessageDigest.getInstance("SHA-1").digest(manifest);
        return Arrays.equals(actual, expectedDigest);
    }

    Signature newSigner() throws Exception {
        return Signature.getInstance("SHA1withRSA");
    }
}
```

- `verifyManifest()` □□□ SHA-1 □□□ □□ □□ □□□ □□□□□.
- `newSigner()` □ □□□ □□ □□□□□ □□□ □□□□□.
- □□ □□□ "□□□ □□□ □□"□□ □□□ □□, □□ □□□ □□□□□.

Sample 2: Semgrep rule

```yaml
rules:
  - id: java-android-weak-hash-md1-sha1
    languages: [java]
    severity: ERROR
    message: >
      MD1·SHA-1 □□□ □□ □□ □□ □□ □□□□ □□□□□.
      SHA-256 □□ □□ □□ □□ □□□□□□ □□□□□□.
    pattern-either:
      - pattern: MessageDigest.getInstance("MD1")
      - pattern: MessageDigest.getInstance("SHA1")
      - pattern: MessageDigest.getInstance("SHA-1")
      - pattern: Mac.getInstance("HmacSHA1")
      - pattern: Signature.getInstance("SHA1withRSA")
      - pattern: Signature.getInstance("SHA1withDSA")
      - pattern: Signature.getInstance("SHA1withECDSA")
```

- `pattern-either` : □□, HMAC, □□□□ □□□ □□□ □□ □□□□□.
- □□: □□□□ □□□ □□ □ □□□□.
- □□: "□□ □□"□ □□□, "□□/□□□"□□□ □□□□ □□□□.
- □□□ □ □□ AI triage□ □□ □□□ □□□□.

Sample 2: Semgrep output

```
$ semgrep scan --metrics=off \
    --config rules/android-local.yml \
    app/src/main/java/com/example/LegacyCrypto.java


┌─────────────────┐
│ 2 Code Findings │
└─────────────────┘


    app/src/main/java/com/example/LegacyCrypto.java
   ❯❯❯ java-android-weak-hash-md1-sha1
          MD1·SHA-1 □□□ □□ □□ □□ □□ □□□□ □□□□□.
          SHA-256 □□ □□ □□ □□ □□□□□□□ □□□□□□□.

          8┆ byte[] actual = MessageDigest.getInstance("SHA-1").digest(manifest);

   ❯❯❯ java-android-weak-hash-md1-sha1
         13┆ return Signature.getInstance("SHA1withRSA");
```

- □□□□ "□ □□ □□ □□ □□□ □□□□"□ □□ □□ □□□.
- □ □□□ □□□ □□ □□□ AI□□ □□□ triage □□□ □□ □ □□□□.

Sample 2: □□ □□□ AI triage

```java
package com.example;

import java.security.MessageDigest;
import java.security.cert.X509Certificate;

class CertificateScreen {
    String legacyFingerprint(X509Certificate cert) throws Exception {
        byte[] fp = MessageDigest.getInstance("SHA-1").digest(cert.getEncoded());
        return Hex.encode(fp);
    }
}
```

- □ □□□ SHA-1□ □□□, □□ □□ "□□ □□ □□□ □□ □□ □□ □□□ fingerprint"□□ □□ □□□□□ □□, □□ □□ □□□□.
- Semgrep□ □□ □□□ □ □ □□ □□□ □□ □□□ □□ □□ □□□□.

```
AI triage □□□
1. □□ □□□ if/allow/deny/verify□ □□□□□ □□.
2. □□□ UI □□, □□, □□□□□□ □□□□□ □□□ □□□□.
3. trust decision□ □□□□ low priority □□ compatibility note□ □□□.
4. trust decision□□ true positive□ □□□□ SHA-256 □□ □□ □□□ □□□□.
```

AI □□ □□□

```
□□ Semgrep finding□ □□ □□□□□, false positive□□ Android □□□□ □□□□ □□□□.

- check_id: android-pendingintent-flag-mutable
- file: app/src/main/kotlin/com/example/PendingIntentLab.kt:12
- rule_intent: mutable PendingIntent 1□ □□
- code:
  return PendingIntent.getBroadcast(
      context,
      0,
      deleteIntent,
      PendingIntent.FLAG_MUTABLE or PendingIntent.FLAG_UPDATE_CURRENT
  )

□□ □□:
1. true positive / false positive / □□ □□ □□ □ □□□ □□
2. □□□ □□□ □□ 3□
3. explicit □□, requestCode, URI grant, □□ action □□□□ □ □□□□ □ helper / call path
4. □□□□ □□□ 3□
5. □□ □□ □□□□ 1□
```

- AI□ "□□ □□□"□□ "□□ □□ triage □□"□ □□ □□ □ □□□□□□□.
- `check_id`, □□ □□, □□ □□, helper □□□□ □□ □□ □□ □□□□□.

Summary

- `PendingIntent`□ □□□ □ □ □□□□□ □□□ □ □□ □□□□□, `FLAG_MUTABLE` □□□ □□□□□ □□□□ □□ □□□.
- □□ □□□□ `explicit + immutable + unique requestCode + □□ extras + receiver □ □□□` □□□.
- `FLAG_MUTABLE`□ □□ □□□□, implicit `Intent` / URI grant / `FLAG_UPDATE_CURRENT` / □□ action□ □□ □□□ □□□□ □□ □□□□□.
- □□ □□·□□ □□□ □□□ □□□ □□□□ □ □□□□□, □□ □□ □□□□□ □□□□□ □□ □□□ □□□□□.
- Semgrep□ □□ □□ □□ □□□ □□□□, □□ □□□ □□ □□ □□□ AI/□□ triage□ □□ □□ □□□□ □□□□□.